



Análise dos Gaps, Expectativas e Evolução Estratégica do CAC

2025

prodam

CAC – Controle de Acesso Corporativo

◆ Expectativas vs Gaps do CAC



O que é o CAC



Cenário Atual



GAP's



**Proposta de
Evolução**

◆ O que é o CAC

- **CAC - Controle de Acesso Corporativo**

O CAC é uma solução composta de aplicações (Webservices SOAP e REST, Recursos de Login Corporativa, Recursos de Administração descentralizada, Logs de acesso) para IAM tradicional

- **Integrar-se com o usuário corporativo**

A governança de identidades é feita em base local ou integrada opcionalmente com Active Directory. Gestão descentralizada de usuários baseado em Hierarquia (Unidade Organizacional) ou através de processo de requisição de mudança centralizado. Autenticação e Autorização por RBAC + ABAC

- **Tecnologias para o legado e para novas aplicações Web, Mobile, WebAPI**

Com mais de 20 anos de uso, integra-se nas aplicações antigas e atuais por protocolos diversos (SAML, OAuth2/OpenID). Utiliza certificado digital na composição de tokens e nas requisições. É desenvolvido em .Net 4.8 e Core e banco de dados Microsoft SQL Server

◆ Cenário Atual

- **Recursos de Gestão de Identidade (IAM)**

- Autenticação e SSO via cookies/tokens e federação com SAML/OAuth2 e integração opcional com AD.
- Gestão de Usuários: Descentralizada e baseada em administradores locais.
- Autorização RBAC+ABAC com endpoints SOAP, REST (claims de autorização)
- Segurança mediante gestão do administrador, políticas de senha e login e MFA por e-mail

- **Recursos de Governança (IGA)**

- Ciclo de Vida: Provisionamento e desprovisionamento e revisão de Acesso de usuários e sistemas por ação manual dos administradores.
- Workflows: Solicitações de acesso são feitas fora do sistema através da interação do usuário, e-mail ou RDM.
- Monitoramento: Acompanhamento de acessos é manual e reativo.

◆ Gap's e Expectativa de ajuste

EXPECTATIVA DO CLIENTE	GAP DO CAC	SOLUÇÃO PROPOSTA
Identificação por CPF para integração	Uso do RF como identificador principal	- Atualizar o CPF no cadastro de usuários e configurar as aplicações para aceitá-lo
Autenticação com MFA e biometria	Autenticação usuário e senha, com MFA por email	- Integração com Gov.br + MFA email ou post notification
Integração com Entra ID	Integração opcional com Active Directory	- Implementar a Integração com Entra ID e outros Provedores baseados em OAuth2/OpenID
Gestão simplificada de usuário e permissões	Gestão complexa. Modelo de restrição nos sistemas legados	- Atualização do modelo de permissão dos sistemas legados; - Integração com processos e sistemas internos (RH, SIGPEC); - Implementação de IA para gestão de acesso.

prodam

CAC – Controle de Acesso Corporativo

◆ Gap's e Expectativa de ajuste

EXPECTATIVA DO CLIENTE	GAP DO CAC	SOLUÇÃO PROPOSTA
Base de autorização nas aplicações	CAC como intermediário centralizador	- Centralização simplifica para padronização - Integração com provedor de identidade de terceiros
Migração facilitada do legado	Conversão automática	- Ajuste dos sistemas do legado para o modelo de permissões e atualização para uso de OAuth2
Governança automatizada	Processos manuais e reativos	- IAM & IGA com automação
Endpoints mais Seguros	Excesso de exposição de dados de usuários	- Ajuste nos endpoints com dados sensíveis (HTTPS, ocultar campos)



◆ Proposta de Evolução

Desenvolver uma nova solução a partir da transformação do CAC - Controle de Acessos Corporativo. Uma **plataforma moderna de IAM & IGA** alinhada às exigências legais, melhores práticas de segurança e necessidades operacionais corporativas da Prefeitura e suas Unidades Organizacionais.

FUNCIONALIDADE IAM/IGA	CAC ATUAL	NOVA SOLUÇÃO
Ciclo de Vida do Usuário	Manual	Automatizado
Revisão de Acesso	Manual (via consultas)	Automatizada (Campanhas Periódicas)
Segregação de Funções (SoD)	Limitada (Admin. Local)	Análise de Risco SoD Automatizada
Autenticação Multifator (MFA)	Básica (Apenas e-mail)	Avançada (Múltiplos fatores + Análise de Risco)
Gestão de Senhas	Básica (Criptografia em BD)	Avançada (Cofre + Detecção de Vazamentos)
Suporte ao usuário	Manual	Suportada por IA
Federação de Identidade	Apenas AD	Integração com EntraID, Gov.BR e outros no padrão OAuth2

prodam



Obrigado!

GDE – Núcleo de Arquitetura
grdnac@prodam.sp.gov.br

prodam